

AVALIAÇÃO DE SEGURANÇA DE UM SERVIDOR FTP EM AMBIENTE CONTROLADO

Identificação, exploração controlada e mitigação de
vulnerabilidade relacionadas à autenticação

Ágata Czkut
Julho • 2026
Uso educacional

Resumo Executivo:

Este relatório apresenta os resultados de uma avaliação de segurança realizada em um servidor FTP configurado em ambiente virtualizado e controlado. O laboratório teve como objetivo demonstrar como o uso de credenciais fracas pode comprometer um serviço exposto à rede por meio de um ataque de dicionário autorizado.

Para a execução do projeto, foi desenvolvido um ambiente isolado utilizando Oracle VirtualBox, composto por uma máquina atacante (Kali Linux) e uma máquina alvo (Ubuntu Server). Durante o laboratório, foram realizadas as etapas de configuração do servidor FTP, reconhecimento do ambiente, enumeração de serviços, validação da autenticação, exploração controlada da vulnerabilidade e aplicação de medidas de mitigação.

Os resultados evidenciaram que a utilização de uma senha fraca possibilitou a obtenção de acesso autenticado ao serviço FTP por meio da ferramenta Medusa. Após a identificação da vulnerabilidade, foram implementadas medidas corretivas, incluindo a alteração da credencial para uma senha robusta e a interrupção do serviço FTP, reduzindo significativamente a superfície de ataque do ambiente.

Todas as atividades foram executadas exclusivamente em ambiente controlado e autorizado, com finalidade educacional, respeitando os princípios éticos da segurança da informação e as boas práticas de testes de intrusão.

Sumário:

1. Introdução
2. Objetivo
3. Escopo
4. Ambiente do Laboratório
5. Arquitetura
6. Metodologia
7. Ferramentas Utilizadas
8. Reconhecimento
9. Enumeração
10. Validação do Serviço
11. Exploração Controlada
12. Análise dos Resultados
13. Classificação do Risco
14. Mitigações
15. Conclusão
16. Lições Aprendidas
17. Referências

1. Introdução:

Este relatório apresenta a execução de um laboratório prático de segurança ofensiva desenvolvido em ambiente virtualizado e autorizado. O objetivo foi demonstrar como credenciais fracas podem comprometer um serviço FTP exposto à rede por meio de um ataque de dicionário controlado. Todas as atividades foram realizadas exclusivamente para fins educacionais, seguindo princípios éticos e boas práticas de testes de segurança.

2. Objetivo:

- Configurar um servidor FTP utilizando o vsftpd em um ambiente Ubuntu.
- Identificar serviços expostos utilizando técnicas de reconhecimento.
- Validar o funcionamento do serviço FTP.
- Demonstrar um ataque de dicionário contra credenciais fracas em ambiente controlado.
- Aplicar medidas de mitigação para reduzir o risco identificado.
- Documentar todas as etapas e os resultados obtidos.

3. Escopo:

Máquina Atacante:

- Kali Linux

Máquina Alvo:

- Ubuntu Server

Serviço Avaliado:

- FTP (vsftpd)

Tipo de Teste:

- Ataque de Dicionário Controlado

Ambiente:

- VirtualBox
- Rede Interna
- Ambiente isolado

4. Ambiente do Laboratório:

Hipervisor	Oracle VirtualBox
Máquina atacante	Kali Linux
Máquina Alvo	Ubuntu Server
Serviço	vsftpd 3.0.5
Cliente FTP	ftp
Scanner	Nmap
Ferramenta de autenticação	Medusa

O ambiente foi implementado utilizando o Oracle VirtualBox, composto por uma máquina atacante (Kali Linux), e uma máquina alvo (Ubuntu Server). Durante a preparação, foram realizados ajustes de conectividade, incluindo configuração dos adaptadores de rede, obtenção de endereços IP via DHCP, definição de uma rede interna para comunicação entre as máquinas e validação da conectividade entre os hosts.

Atividade:	Status:
Configuração do NAT	✓
Configuração da Rede Interna	✓
Obtenção de IP via DHCP	✓
Validação da conectividade	✓
Instalação do vsftpd	✓

5. Arquitetura do Ambiente:



6. Metodologia:

Foi utilizado uma metodologia inspirada nas fases tradicionais de um teste de intrusão:

1. Preparação do ambiente
2. Configuração do servidor
3. Reconhecimento
4. Enumeração
5. Validação do serviço
6. Exploração controlada
7. Mitigação
8. Validação pós mitigação
9. Documentação

7. Ferramentas:

- VirtualBox
- Ubuntu Server
- Kali Linux
- Nmap
- FTP
- Medusa
- vsftpd

7.1. Preparação do Ambiente:

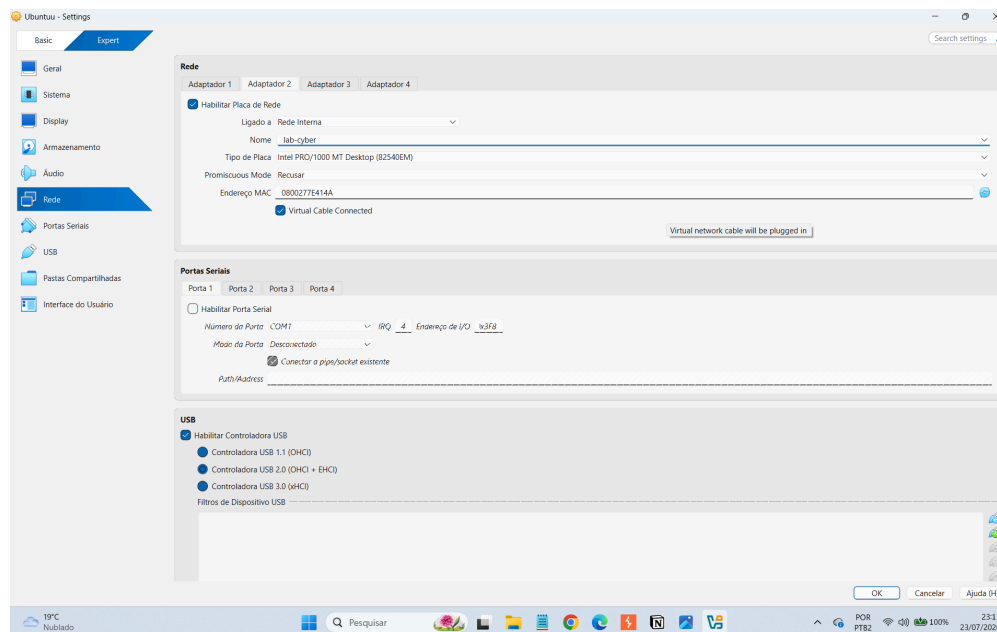
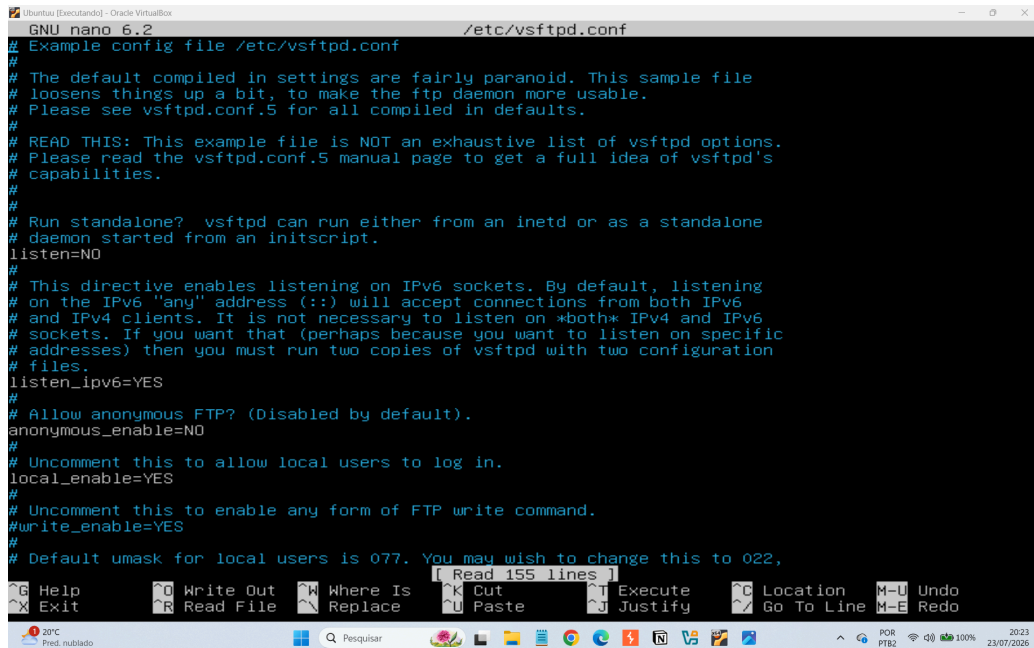


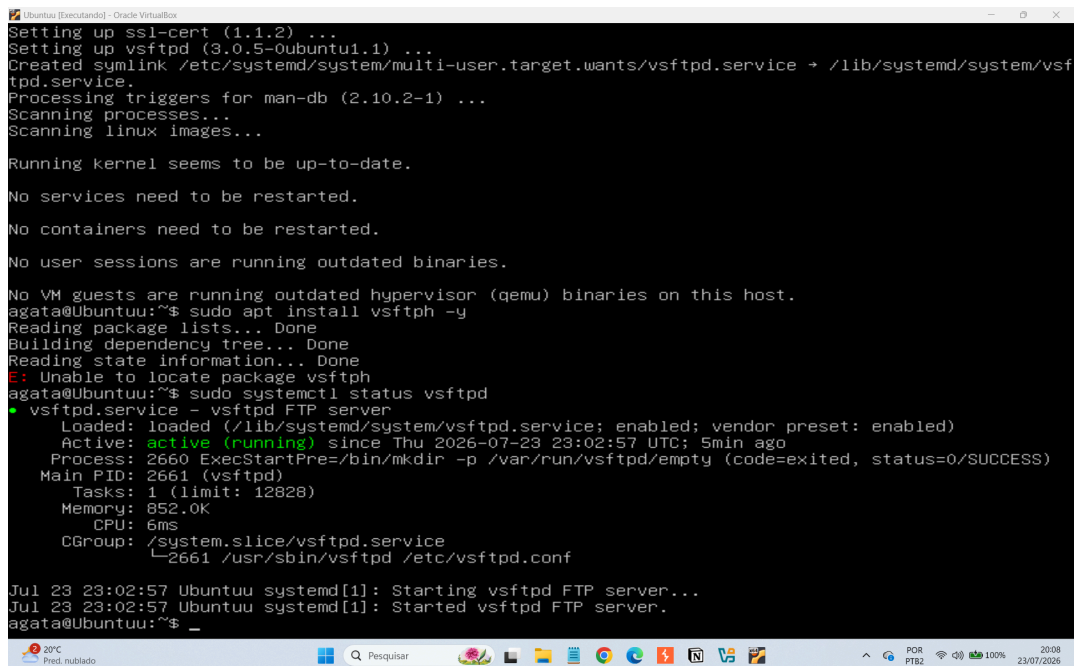
Figura 1 - Topologia do laboratório no VirtualBox

7.2. Instalação e Configuração do Servidor FTP:



```
GNU nano 6.2 /etc/vsftpd.conf
# Example config file /etc/vsftpd.conf
#
# The default compiled in settings are fairly paranoid. This sample file
# loosens things up a bit, to make the ftp daemon more usable.
# Please see vsftpd.conf.5 for all compiled in defaults.
#
# READ THIS: This example file is NOT an exhaustive list of vsftpd options.
# Please read the vsftpd.conf.5 manual page to get a full idea of vsftpd's
# capabilities.
#
# Run standalone? vsftpd can run either from an inetd or as a standalone
# daemon started from an initscript.
listen=NO
#
# This directive enables listening on IPv6 sockets. By default, listening
# on the IPv6 "any" address (:::) will accept connections from both IPv6
# and IPv4 clients. It is not necessary to listen on *both* IPv4 and IPv6
# sockets. If you want that (perhaps because you want to listen on specific
# addresses) then you must run two copies of vsftpd with two configuration
# files.
listen_ipv6=YES
#
# Allow anonymous FTP? (Disabled by default).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
write_enable=YES
#
# Default umask for local users is 077. You may wish to change this to 022,
# if you want to allow users to create new files in their home directories.
#
# Read 155 lines
Help Write Out Where Is Cut Execute Location M-U Undo
Exit Read File Replace Paste Justify Go To Line M-E Redo
```

Figura 2 – Configuração do arquivo vsftpd.conf



```
Setting up ssl-cert (1.1.2) ...
Setting up vsftpd (3.0.5-0ubuntu1.1) ...
Created symlink /etc/systemd/system/multi-user.target.wants/vsftpd.service → /lib/systemd/system/vsftpd.service.
Processing triggers for man-db (2.10.2-1) ...
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
agata@Ubuntu:~$ sudo apt install vsftpd -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
E: Unable to locate package vsftpd
agata@Ubuntu:~$ sudo systemctl status vsftpd
vsftpd.service - vsftpd FTP server
Loaded: loaded (/lib/systemd/system/vsftpd.service; enabled; vendor preset: enabled)
Active: active (running) since Thu 2026-07-23 23:02:57 UTC; 5min ago
Process: 2660 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
Main PID: 2661 (vsftpd)
Tasks: 1 (limit: 12828)
Memory: 852.0K
CPU: 6ms
CGroup: /system.slice/vsftpd.service
└─2661 /usr/sbin/vsftpd /etc/vsftpd.conf

Jul 23 23:02:57 Ubuntu systemd[1]: Starting vsftpd FTP server...
Jul 23 23:02:57 Ubuntu systemd[1]: Started vsftpd FTP server.
agata@Ubuntu:~$
```

Figura 3 – Serviço vsftpd ativo no Ubuntu Server

7.3. Enumeração:

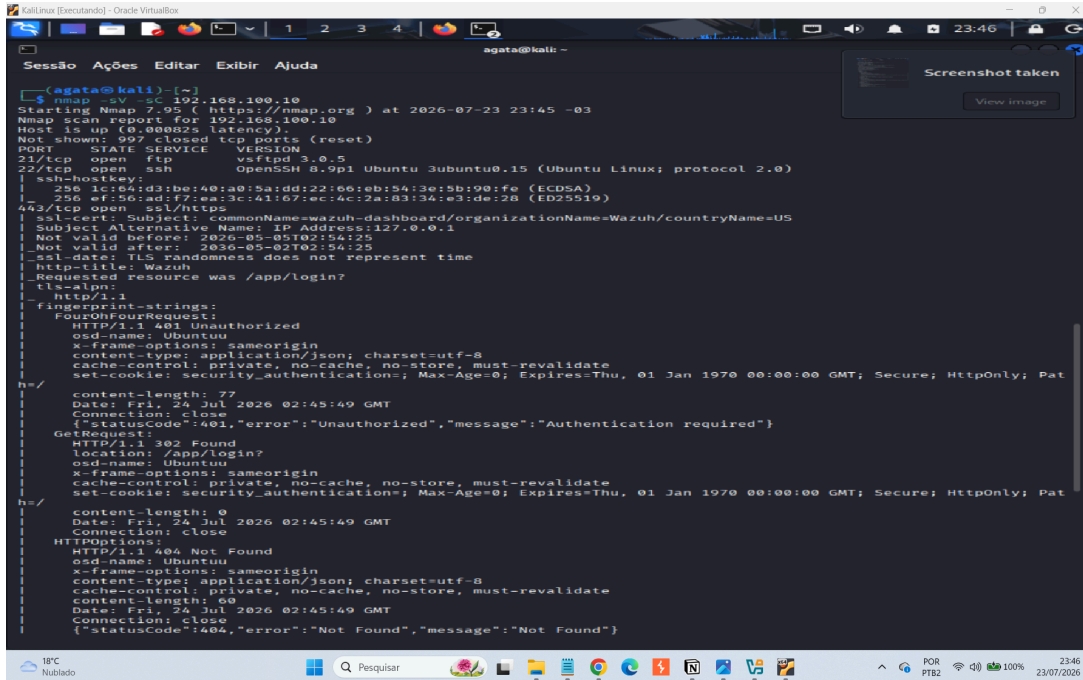


Figura 4 – Enumeração dos serviços utilizando Nmap

7.4. Validação do Serviço FTP:

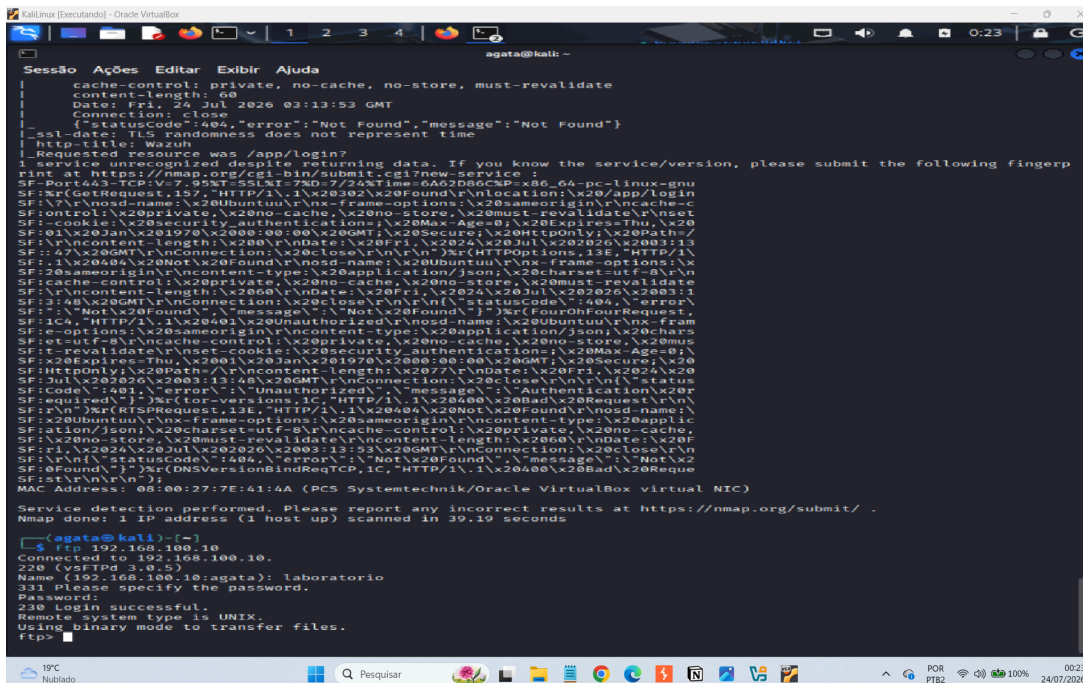


Figura 5 – Validação das credenciais no serviço FTP

7.5. Ataque de Dicionário:

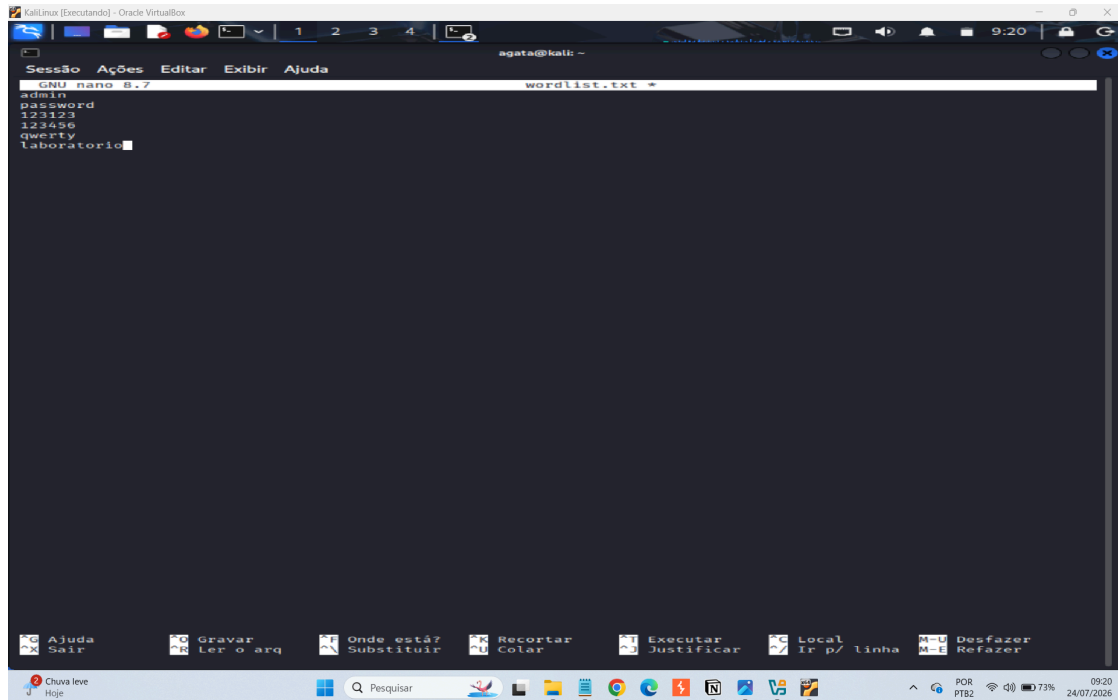


Figura 6 – Criação da Wordlist

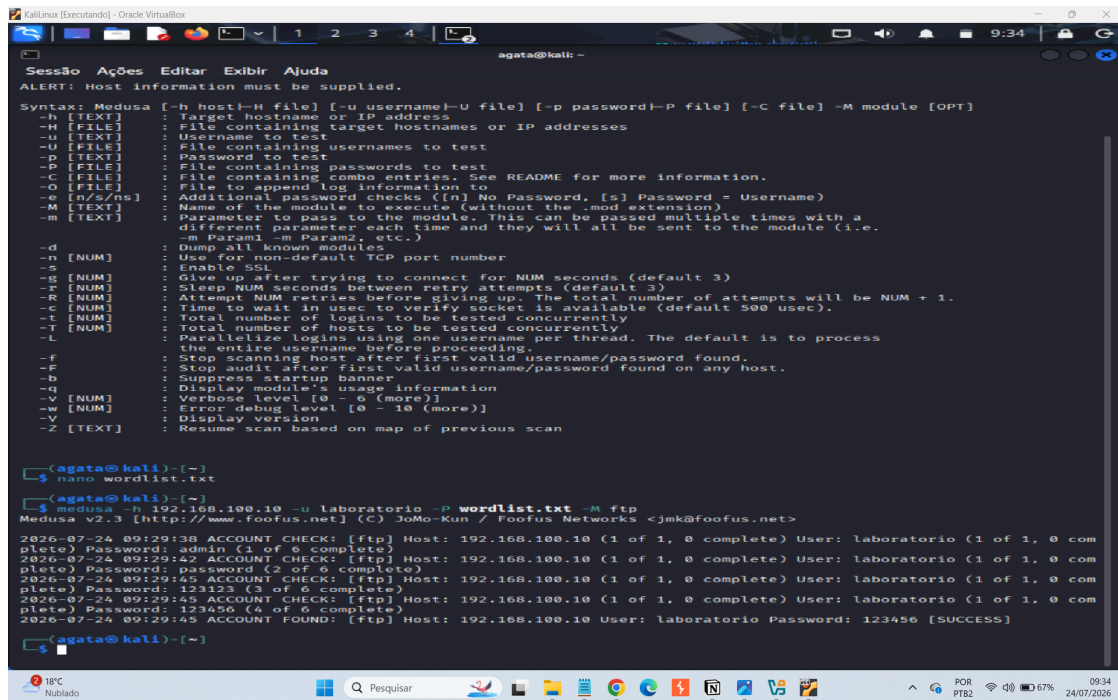


Figura 7 – Execução do ataque de dicionário com Medusa

7.6. Mitigação:

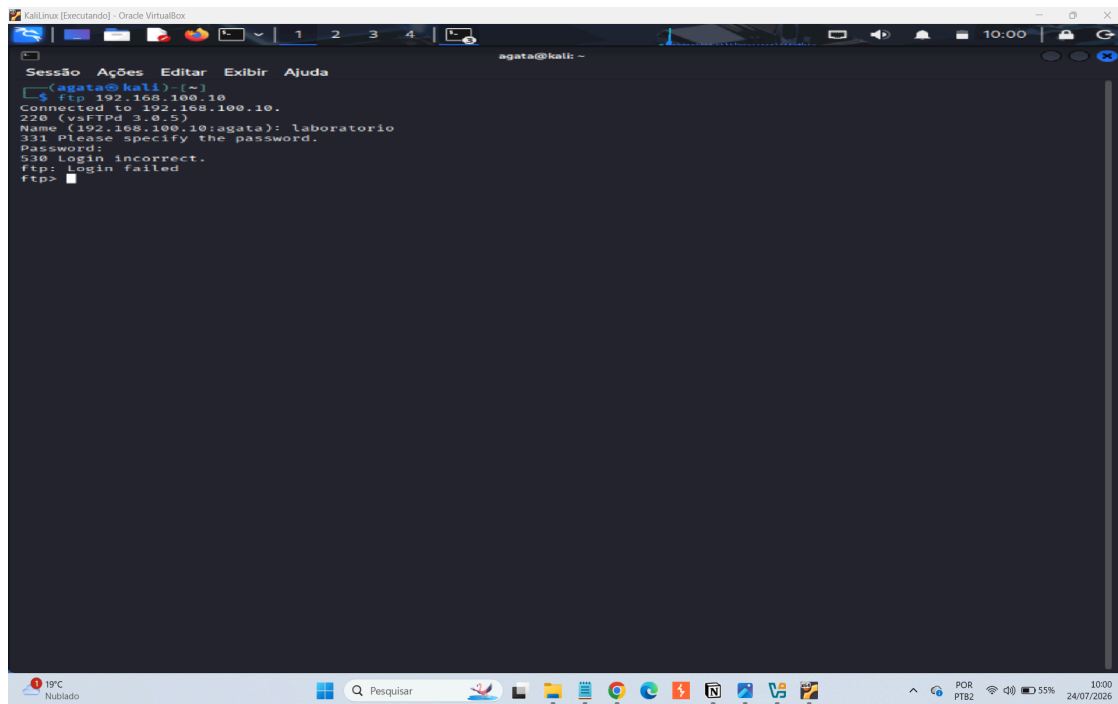


Figura 8 – Falha de autenticação utilizando a senha antiga

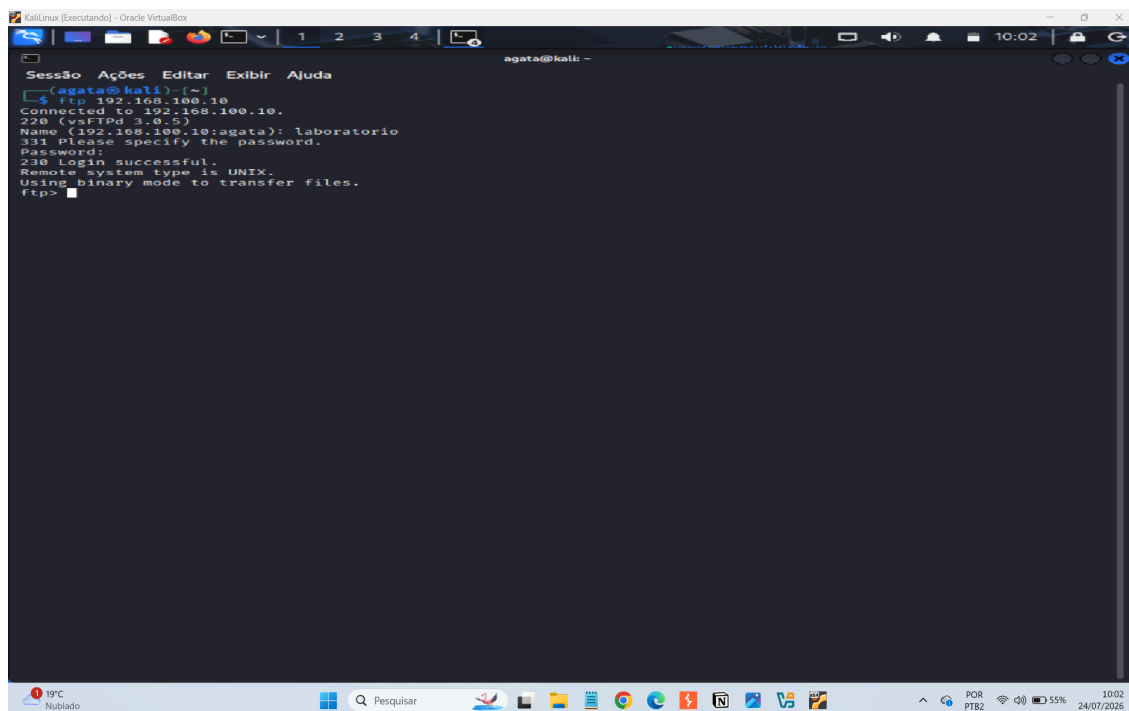


Figura 9 – Autenticação bem-sucedida após atualização da credencial

7.7. Desativação do Serviço:

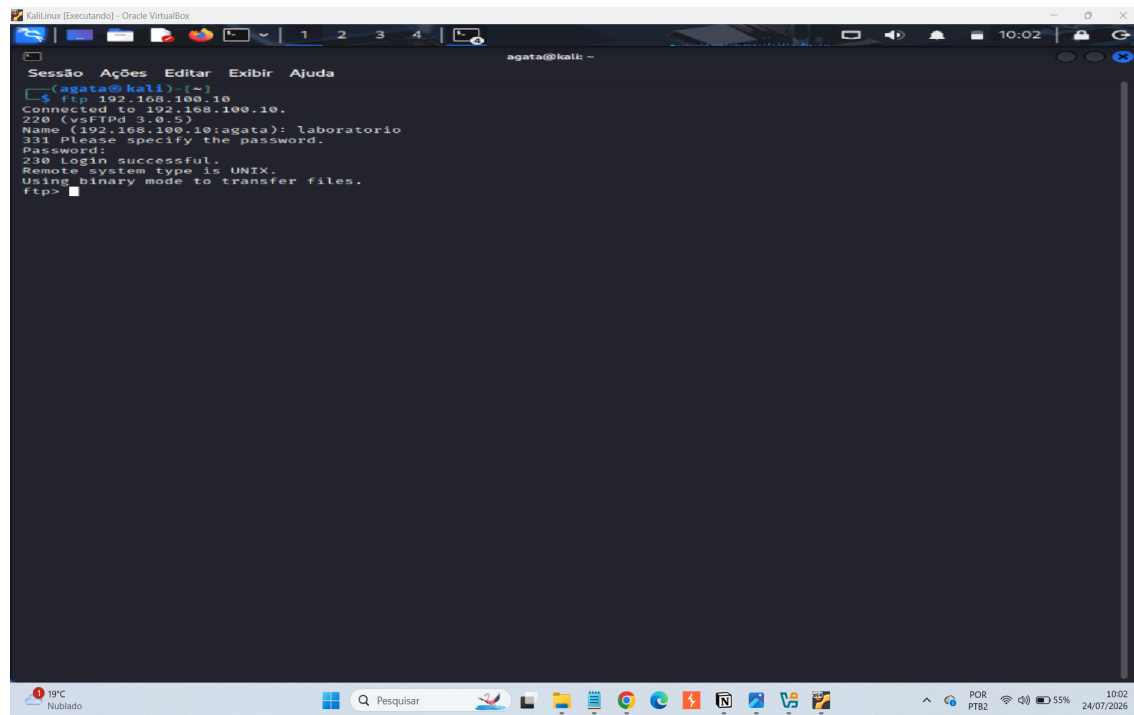


Figura 10 – Serviço FTP interrompido após aplicação das medidas de mitigação

8. Reconhecimento:

Comando:

```
nmap -sV -sC 192.168.100.10
```

Resultado:

21/tcp open ftp vsftpd 3.0.5

22/tcp open ssh OpenSSH 8.9

443/tcp open ssl/https

Análise técnica de cada porta e sua relevância.

9. Validação:

Conexão:

ftp 192.168.100.10

Resultado:

220 (vsFTPd 3.0.5)

230 Login successful

Explicação do banner e da autenticação.

10. Exploração:

Wordlist criada.

Execução:

```
medusa -h 192.168.100.10 -u laboratorio -P wordlist.txt -M ftp
```

Resultado:

ACCOUNT FOUND

User: laboratorio

Password: 123456

Explicação do ataque de dicionário.

11. Avaliação do Risco:

Vulnerabilidade	Uso de credencial fraca
Severidade	Alta
Probabilidade	Alta
Impacto	Médio/Alto
Vetor de ataque	Serviço FTP
Recomendação	Fortalecimento da autenticação

12. Mitigações:

- Alteração de senha
- Política de senhas fortes
- Uso de SFTP
- Fail2ban
- Monitoramento de tentativas de login
- Desativação do FTP quando não necessário

Também documentamos a validação da mitigação: senha antiga rejeitada e nova senha aceita.

13. Conclusão:

Uma conclusão destacando que o risco não estava em uma falha do vsftpd, mas na combinação entre um serviço exposto e uma política de autenticação inadequada, e que a aplicação das medidas mitigatórias reduziu significativamente a exposição.

14. Lições Aprendidas:

Durante a execução deste laboratório foi possível compreender a importância de:

- Configuração correta da infraestrutura antes da execução dos testes.
- Enumeração como etapa fundamental de um pentest.
- Impacto de credenciais fracas em serviços expostos.
- Aplicação de medidas de mitigação para redução da superfície de ataque.
- Documentação técnica como parte essencial de uma avaliação de segurança.

Essa seção mostra reflexão sobre o projeto.

15. Referências:

- **Nmap Project.** *Nmap Reference Guide*. Disponível em: <https://nmap.org/book/man.html>. Acesso em: 24 jul. 2026.
- **vsftpd.** *Very Secure FTP Daemon*. Disponível em: <https://security.appspot.com/vsftpd.html>. Acesso em: 24 jul. 2026.
- **Medusa Parallel Network Login Auditor.** *Medusa Documentation*. Disponível em: <https://github.com/jmk-foofus/medusa>. Acesso em: 24 jul. 2026.
- **OpenSSH.** *OpenSSH Manual Pages*. Disponível em: <https://www.openssh.com/manual.html>. Acesso em: 24 jul. 2026.
- **OWASP Foundation.** *OWASP Web Security Testing Guide*. Disponível em: <https://owasp.org/www-project-web-security-testing-guide/>. Acesso em: 24 jul. 2026.
- **OWASP Foundation.** *OWASP Top 10*. Disponível em: <https://owasp.org/www-project-top-ten/>. Acesso em: 24 jul. 2026.
- **National Institute of Standards and Technology (NIST).** *Digital Identity Guidelines – Authentication and Lifecycle Management (SP 800-63B)*. Disponível em: <https://csrc.nist.gov/pubs/sp/800/63/b/upd3/final>. Acesso em: 24 jul. 2026.
- **Center for Internet Security (CIS).** *CIS Controls Version 8*. Disponível em: <https://www.cisecurity.org/controls>. Acesso em: 24 jul. 2026.
- **Oracle.** *Oracle VM VirtualBox User Manual*. Disponível em: <https://www.virtualbox.org/manual/>. Acesso em: 24 jul. 2026.
- **Ubuntu Documentation.** *Ubuntu Server Guide*. Disponível em: <https://ubuntu.com/server/docs>. Acesso em: 24 jul. 2026.
- **FTP – RFC 959.** *File Transfer Protocol (FTP)*. Disponível em: <https://www.rfc-editor.org/rfc/rfc959>. Acesso em: 24 jul. 2026.
- **The Linux man-pages Project.** *ftp(1), passwd(1), systemctl(1)*. Disponível em: <https://man7.org/linux/man-pages/>. Acesso em: 24 jul. 2026.

